Лабораторна робота №5. Безпека сервісних API

Тема: Аутентифікація, авторизація, обмеження доступу
Ключові аспекти: API Gateway: Kong, NGINX, Amazon API Gateway
Протоколи безпеки: OAuth 2.0, OpenID Connect, JWT (Json Web Token)
Rate Limiting та Throttling: контроль навантаження CORS, CSRF, TLS — базові рівні захисту Zero Trust підхід для мікросервісів
Приклади: безпечний login, багаторівнева авторизація,Multi-Factor Authentication (MFA)

Теоретичні відомості

Ознайомитися з презентацію та лекцією по авторизаціях за посиланням
https://docs.google.com/presentation/d/1Nm1aHpwjwEOommOR6A-mXOTkY-3F43QaijlXzBoUYbo/edit?usp=sharing
https://youtu.be/jjcuLqFDrgE
та про CORS https://youtu.be/wuP8wqE7NdM?si=sfjglXtY-Nys2j91&t=165

Хід роботи

1. Станом на даний момент з попередніх ЛР Ви маєте проєкт з 2ма+ мікросервісами та API Gateway
2. З допомогою вбудованого в Ваш веб-фрейморк функціоналу дозволити сайту кафедри cad.kpi.ua доступ до вашого ресурсу (не забудьте переконатися, що апі гейтвей не перезаписує необхідні заголовки) (2)
3. З допомогою безкоштовних інструментів KeyKloak або AWS cognito реалізувати вхід в систему з допомогою OAUTH2 Auth code Grant flow
    a. Для мінімального балу достатньо просто налаштувати аус сервер та підключити сторонній айдентіті провайдер (наприклад, кнопку Login with Atlassian Account) (1)
    b. Захистити ендпоінти застосунку з допомогою JWT токенів (2)
    c. Реалізувати окремі OAUTH Scopes для захищених ресурсів різних сервісів (1)

Контрольні питання

1. Що таке JWT та з яких частин він складається?
2. Чим відрізняється автентифікація від авторизації?
3. Поясніть least privilege principle
4. Що таке Oauth2 Grant flows
5. Що таке OIDC
6. CORS